Séance 3 : Le droit avant l'architecture

Vendredi 6 novembre, 11h30 à 13h, en visio. Sortie d'information R3 à 11h30. Rendu 2 à 13h.

Sommaire

- La règle
- L'histoire de Thomas
  - Une application pour motiver les adhérents
  - Des données de santé, vraiment ?
  - Deux ans plus tard : « et si on s'en servait pour les tarifs ? »
  - Claire demande une analyse d'impact
  - Où sont les données, au fait ?
  - Le score qui fixe les prix
  - Un adhérent écrit
- En résumé
- Exercice flash, 5 minutes
- Les bases à garder sous la main
  - Le RGPD en une page
  - Les grands principes
  - Les six bases légales (article 6)
  - Les données de santé (article 9)
  - Anonymiser ou pseudonymiser
  - L'hébergement HDS
  - Les droits des personnes
  - L'IA et le dispositif médical
- Déroulé
- Livrable L3 : AIPD courte
- À la fin de la séance
- Entre le 6 et le 29 novembre

La règle

Le droit se décide avant l'architecture.

Où l'on héberge, qui accède à quoi, combien de temps on garde, ce qu'on a le droit de croiser : ce sont des décisions juridiques avant d'être des décisions techniques. Une architecture dessinée avant de les avoir prises sera redessinée, tard et cher.

L'histoire de Thomas

Une application pour motiver les adhérents

Thomas est responsable du numérique dans une mutuelle régionale. Il veut lancer une application de coaching : les adhérents connectent leur montre, l'application compte leurs pas, suit leur sommeil, et leur envoie des encouragements.

Avant de commencer, il passe voir Claire, la déléguée à la protection des données, la DPO. Elle lui pose trois questions, toujours les mêmes, parce que c'est ce que demande le RGPD.

> Le RGPD, c'est le règlement européen qui encadre depuis 2018 tout ce qu'on fait avec des **données personnelles**, c'est-à-dire toute information qui permet d'identifier quelqu'un, directement ou en recoupant. Un nom, bien sûr, mais aussi un identifiant de montre, une adresse IP, ou une suite de mesures assez précise pour retrouver une personne. Et tout ce qu'on fait avec ces données s'appelle un **traitement** : collecter, stocker, croiser, analyser, transmettre, et même supprimer.

Les trois questions de Claire :

- **« À quoi ça sert ? »** C'est la **finalité**. Ici : motiver les adhérents à bouger. On ne pourra pas, plus tard, utiliser ces données pour autre chose sans se reposer la question.
- **« Qu'est-ce qui t'autorise à le faire ? »** C'est la **base légale**. Le RGPD en prévoit six, et il faut en choisir une avant de commencer. Pour une application que l'adhérent installe s'il le souhaite, ce sera son consentement.
- **« Est-ce que ce sont des données de santé ? »** La question qui change tout.

Des données de santé, vraiment ?

Thomas répond que non : ce sont des pas et des heures de sommeil, pas des diagnostics.

Claire nuance. Pour la CNIL, une donnée devient une donnée de santé de trois façons :

- **par nature** : une maladie, un traitement, un résultat d'analyse, un passage à l'hôpital ;
- **par croisement** : des données anodines qui, rapprochées, permettent de tirer une conclusion sur la santé de quelqu'un ;
- **par destination** : des données qu'on utilise pour juger de l'état de santé d'une personne.

Tant qu'on compte des pas pour envoyer des encouragements, on reste dans le bien-être. Mais elle prévient Thomas : la frontière tient à l'usage, et il suffit d'un changement d'usage pour la franchir.

Thomas note tout. L'application sort, les adhérents acceptent les conditions, tout le monde est content.

Deux ans plus tard : « et si on s'en servait pour les tarifs ? »

L'équipe des actuaires a une idée. En croisant les pas et le sommeil avec les remboursements de soins, on pourrait mieux évaluer le risque de chaque adhérent, et ajuster les cotisations.

Techniquement, c'est une requête. Juridiquement, tout est à refaire :

- **La finalité change.** Les adhérents ont accepté d'être motivés, pas d'être tarifés.
- **Les données basculent.** Croisées avec des remboursements, utilisées pour évaluer un état de santé, ce sont désormais des données de santé, par croisement et par destination.

Or les données de santé font partie des **données sensibles**. L'article 9 du RGPD en interdit le traitement par principe, sauf exceptions encadrées : le consentement explicite, la prise en charge médicale, la santé publique, la recherche. Aucune ne couvre le calcul d'une cotisation.

L'architecture est déjà construite. Le projet repart de zéro côté juridique.

Claire demande une analyse d'impact

Claire arrête le projet et demande une AIPD, une Analyse d'Impact relative à la Protection des Données. Elle est obligatoire quand un traitement présente un risque élevé pour les personnes. Pour le savoir, la CNIL propose neuf critères :

1. évaluation ou notation ;
2. décision automatisée avec effet important ;
3. surveillance systématique ;
4. données sensibles ;
5. grande échelle ;
6. croisement de données ;
7. personnes vulnérables ;
8. usage innovant ;
9. traitement qui peut priver d'un droit ou d'un service.

Deux critères réunis suffisent en général. Le projet des actuaires en coche au moins quatre.

L'AIPD suit toujours le même chemin : décrire le traitement, vérifier qu'il est nécessaire et proportionné, identifier les risques (accès illégitime, modification non désirée, disparition des données), les coter en vraisemblance et en gravité, puis décider des mesures.

Où sont les données, au fait ?

L'application a été développée par une start-up, qui héberge toutes les données sur ses propres serveurs. Thomas relit le contrat, et découvre trois problèmes.

Premier problème : l'hébergeur. En France, les données de santé recueillies pour la prévention, le diagnostic, les soins ou le suivi médico-social ne peuvent être hébergées, pour le compte d'un établissement ou d'un patient, que par un hébergeur **certifié HDS** (Hébergeur de Données de Santé). La certification est délivrée par des organismes agréés, selon un référentiel de l'Agence du numérique en santé. Elle garantit la sécurité, la traçabilité des accès et la continuité du service, et la dernière version du référentiel exige que les données restent dans l'Espace économique européen.

Pour un coaching sportif, on peut discuter : est-ce de la prévention ? Les juristes de la mutuelle penchent pour le oui dès que les données servent à juger la santé de quelqu'un. Et dans le doute, on héberge chez un certifié. La start-up ne l'est pas.

Ce que ça implique pour un projet data : le choix de l'hébergeur n'est pas libre. Il se fait dans la liste des certifiés, il se vérifie activité par activité, et il coûte plus cher. Il se décide donc avant de dessiner l'architecture.

Deuxième problème : « anonymisées ». Une clause autorise la start-up à réutiliser les données « anonymisées » pour améliorer ses produits. Personne n'a vérifié ce que voulait dire ce mot.

> **Un aparté sur l'anonymisation.** Au sens du RGPD, une donnée anonyme est une donnée dont on ne peut plus jamais retrouver la personne, par aucun moyen raisonnable : ni en isolant un individu, ni en

> reliant deux jeux de données, ni en déduisant une information sur lui. Elle sort alors du RGPD.
>
> En pratique, dès qu'on fait des statistiques fines, ça ne tient presque jamais. Un adhérent de 74 ans, dans une petite commune, qui marche 20 000 pas par jour, se retrouve tout seul dans sa case. Remplacer son nom par un numéro, c'est de la **pseudonymisation** : utile, mais la donnée reste personnelle, avec toutes les obligations qui vont avec.
>
> Si on écoute les juristes jusqu'au bout, on n'a plus de données exploitables. Si on écoute les équipes data jusqu'au bout, on garde tout, au cas où. La bonne façon de faire est entre les deux : on pseudonymise dès l'entrée, on ne garde que les colonnes utiles, on agrège avec un nombre minimal de personnes par case, on limite qui accède aux données détaillées, et on traite le risque de réidentification comme un risque à mesurer, pas comme une case à cocher.

Troisième problème : la sortie. Rien n'est prévu pour récupérer les données si le contrat s'arrête.

Au sens du RGPD, la start-up est un **sous-traitant** : elle traite les données pour le compte de la mutuelle, qui reste **responsable du traitement**. Ce que la start-up fait des données reste sous la responsabilité de la mutuelle, et le contrat qui les lie doit l'écrire noir sur blanc.

Le score qui fixe les prix

Les actuaires voulaient un modèle d'IA pour noter chaque adhérent. Depuis l'AI Act, le règlement européen sur l'intelligence artificielle, un système d'IA utilisé pour évaluer le risque et fixer le prix d'une assurance santé est classé **à haut risque** : documentation, qualité des données, supervision humaine, contrôle avant mise en service.

Et si le score servait à orienter des soins plutôt qu'à fixer des prix, il pourrait devenir un dispositif médical, avec un marquage CE à obtenir avant toute utilisation.

Un adhérent écrit

Pendant ce temps, un adhérent a entendu parler du projet. Il demande à recevoir toutes les données que la mutuelle détient sur lui, et à qui elles ont été transmises. La mutuelle a un mois pour répondre, deux de plus si la demande est complexe. Et « toutes les données », ça inclut celles qui sont chez la start-up.

En résumé

- Chaque traitement a une finalité et une base légale, choisies avant de commencer. Changer de finalité, c'est repartir de zéro.
- Une donnée devient une donnée de santé par nature, par croisement ou par destination. La frontière tient à l'usage.
- Les données de santé sont interdites de traitement par principe, sauf exceptions de l'article 9.
- Deux critères CNIL réunis, et l'AIPD est en général obligatoire.
- Les données de santé recueillies dans un cadre de soins ou de prévention s'hébergent chez un certifié HDS. Le choix de l'hébergeur se fait avant l'architecture.
- Pseudonymisé ne veut pas dire anonyme. Le bon réglage se trouve entre le tout-garder et le plus-rien.
- Un sous-traitant reste sous votre responsabilité, et le contrat dit à qui appartient la donnée.
- Un score qui fixe un prix d'assurance santé, ou qui aide une décision médicale, change de catégorie réglementaire.
- Une personne peut demander toutes ses données : réponse sous un mois, sous-traitants compris.

Exercice flash, 5 minutes

Pour chacun de ces traitements, une AIPD est-elle nécessaire ? Citez les critères que vous retenez.

1. Le fichier des adhérents d'un club de sport, pour envoyer les convocations.
2. Un score de risque de chute calculé pour les résidents d'un EHPAD à partir de capteurs de mouvement.
3. La vidéosurveillance du parking d'un supermarché.

Les bases à garder sous la main

Cette fiche ne se récite pas. Elle sert pendant l'atelier, pour faire votre AIPD sans aller chercher ailleurs.

Le RGPD en une page

- **Donnée personnelle** : toute information qui permet d'identifier une personne, directement ou indirectement.
- **Traitement** : toute opération sur ces données, de la collecte à la suppression.
- **Responsable du traitement** : celui qui décide de la finalité et des moyens. Il répond de tout.
- **Sous-traitant** : celui qui traite pour le compte du responsable. Un contrat doit encadrer ce qu'il a le droit de faire.
- **DPO** : la personne chargée de conseiller et de contrôler la conformité. Obligatoire pour les organismes publics et pour ceux qui traitent des données sensibles à grande échelle.
- **Sanctions** : jusqu'à 20 M€ ou 4 % du chiffre d'affaires mondial annuel, le montant le plus élevé étant retenu.

Les grands principes

Tout traitement doit respecter, en même temps :

- une **finalité** déterminée et légitime, fixée avant de commencer ;
- la **minimisation** : seulement les données nécessaires à cette finalité ;
- l'**exactitude** : des données à jour, corrigées si besoin ;
- une **durée de conservation** limitée et justifiée, puis suppression ou archivage ;
- la **sécurité** : confidentialité, intégrité, disponibilité ;
- la **transparence** : les personnes savent ce qu'on fait de leurs données.

Les six bases légales (article 6)

Base légale	Exemple
Consentement	Une application que l'utilisateur choisit d'installer
Exécution d'un contrat	Les données nécessaires pour facturer un abonnement
Obligation légale	La conservation des factures pour l'administration fiscale
Sauvegarde des intérêts vitaux	Une urgence médicale où la personne ne peut pas consentir
Mission d'intérêt public	Une collectivité qui gère un service public
Intérêt légitime	La lutte contre la fraude, si elle ne déséquilibre pas les droits des personnes

Les données de santé (article 9)

Interdites de traitement par principe. Les exceptions les plus utiles en pratique :

- le **consentement explicite** de la personne, pour une finalité précise ;
- la **prise en charge** médicale : prévention, diagnostic, soins, gestion des services de santé ;
- la **santé publique** ;
- la **recherche**, avec un cadre spécifique en France.

Anonymiser ou pseudonymiser

	Pseudonymisation	**Anonymisation**
Ce qu'on fait	On remplace les identifiants par un code	On rend toute réidentification impossible
Réversible ?	Oui, avec la table de correspondance	Non
Reste soumis au RGPD ?	Oui	Non
En pratique	La règle par défaut dans un projet data	Rare dès qu'on garde des données fines

L'hébergement HDS

- Obligatoire pour héberger des données de santé recueillies lors d'activités de prévention, de diagnostic, de soins ou de suivi médico-social, pour le compte de celui qui les a produites ou du patient.
- Certification délivrée par un organisme agréé, sur un référentiel de l'Agence du numérique en santé.
- Elle se vérifie activité par activité : héberger des serveurs n'est pas la même chose qu'infogérer ou sauvegarder.
- Le référentiel actuel exige un stockage dans l'Espace économique européen.

Les droits des personnes

Accès, rectification, effacement, opposition, limitation, portabilité. Réponse sous un mois, prolongeable de deux mois si la demande est complexe, données détenues par les sous-traitants comprises.

L'IA et le dispositif médical

- **AI Act** : les systèmes d'IA sont classés par niveau de risque. Un système à haut risque, comme la tarification d'une assurance santé, doit être documenté, contrôlé, et supervisé par un humain.
- **Dispositif médical** : un logiciel qui aide au diagnostic ou à la décision de soins peut en être un. Il lui faut alors un marquage CE avant toute utilisation sur des patients.

Déroulé

11h30. Sortie d'information R3, registre et entrée R3 du journal.

11h45 à 12h15. Capsule : l'histoire de Thomas, et l'exercice.

12h15 à 12h30. L'imprévu de la sortie R3, en groupe : votre réponse en dix lignes. Qui la reçoit, qui répond, dans quel délai, et que faites-vous des données qui ne sont pas chez Ombelle ?

12h30 à 13h. En sous-salles, lancement de L3, avec la fiche des bases sous les yeux.

13h. Rendu 2 dans le devoir Teams : entrée R3 du journal, réponse au patient et registre à jour.

Livrable L3 : AIPD courte

Deux pages au plus, méthode CNIL simplifiée, sur deux traitements : la télésurveillance des patients à domicile, et le score de réhospitalisation envisagé.

1. Pour chaque traitement : finalité, base légale, données collectées, durée de conservation.
2. Trois risques : accès illégitime aux données, modification non désirée, disparition. Chacun coté de 1 à 4 en vraisemblance et en gravité, chaque cote justifiée par un fait du cas.
3. Deux mesures par risque, dont au moins une qui change l'architecture.
4. Ce qu'il faut modifier dans le contrat avec le fabricant des capteurs.

À la fin de la séance

- Entrée R3 du journal
- Réponse au patient, en dix lignes
- Registre à jour
- L3 lancée, à finir en autonomie

Les trois premiers partent au rendu 2, vendredi à 13h, dans le devoir Teams.

Entre le 6 et le 29 novembre

Aucune sortie d'information pendant quatre semaines. Vous finissez L3, vous reprenez L1, L2 et le registre à la lumière de tout ce que vous savez.

Rendu 3 dans le devoir Teams le dimanche 29 novembre à 23h59 : L1, L2, L3 et le registre à jour.